

AN TOÀN THÔNG TIN (INSE330380)

CHƯƠNG IV AN TOÀN CƠ SỞ DỮ LIỆU

Ths. ĐỖ MINH HẬU

- ☐ Giới thiệu bài học
- ☐ Cơ sở dữ liệu: Tầm quan trọng, đặc tính
- ☐ An toàn cơ sở dữ liệu
- ☐ Giải pháp an toàn trong các cơ sở dữ liệu- Database Access Control
- ☐ Các cuộc tấn công vào cơ sở dữ liệu: SQL Injection, Inference Attacks on Databases
- ☐ Phòng chống tấn công cơ sở dữ liệu
- ☐ Tóm tắt
- ☐ Quizze

An toàn cơ sở dữ liệu có ý nghĩa vô cùng quan trọng trong các tổ chức doanh nghiệp, vì sự mất an toàn về CSDL có thể gây thiệt hại lớn về kinh doanh và uy tín thương hiệu. Do đó, hiện nay rất nhiều tổ chức quan tâm đến vấn đề an toàn CSDL



CSDL vô cùng quan trọng đối với các tổ chức cũng như cá nhân

- ☐ CSDL ảnh hưởng đến cuộc sống hàng ngày của chúng ta rất rộng rãi, nó chịu trách nhiệm về nhiều dịch vụ mà chúng ta sử dụng.
- ☐ CSDL ở khắp mọi nơi, nó giúp các hoạt động của con người được thực hiện dễ dàng hơn như tìm kiếm thông tin trên Internet, GPS, InternetBanking, ...
- ☐ CSDL đem lại có rất nhiều thứ thú vị và hữu ích khác như giải trí, giao tiếp...

- ❑ Tập trung dữ liệu có giá trị cao (thường bao gồm dữ liệu nhạy cảm: tài chính, vận hành)
- ❑ Dữ liệu có cấu trúc và ràng buộc (schema, khóa, constraint)
- ❑ Truy cập qua hệ quản trị CSDL (DBMS) bằng truy vấn hoặc thông qua ứng dụng/chương trình
- ❑ Dùng SQL để truy vấn (CSDL quan hệ)
- ❑ Hỗ trợ giao dịch: đọc/ghi (đảm bảo dữ liệu nhất quán)
- ❑ Có lớp trừu tượng hoá truy cập như view, stored procedure (tuỳ hệ)

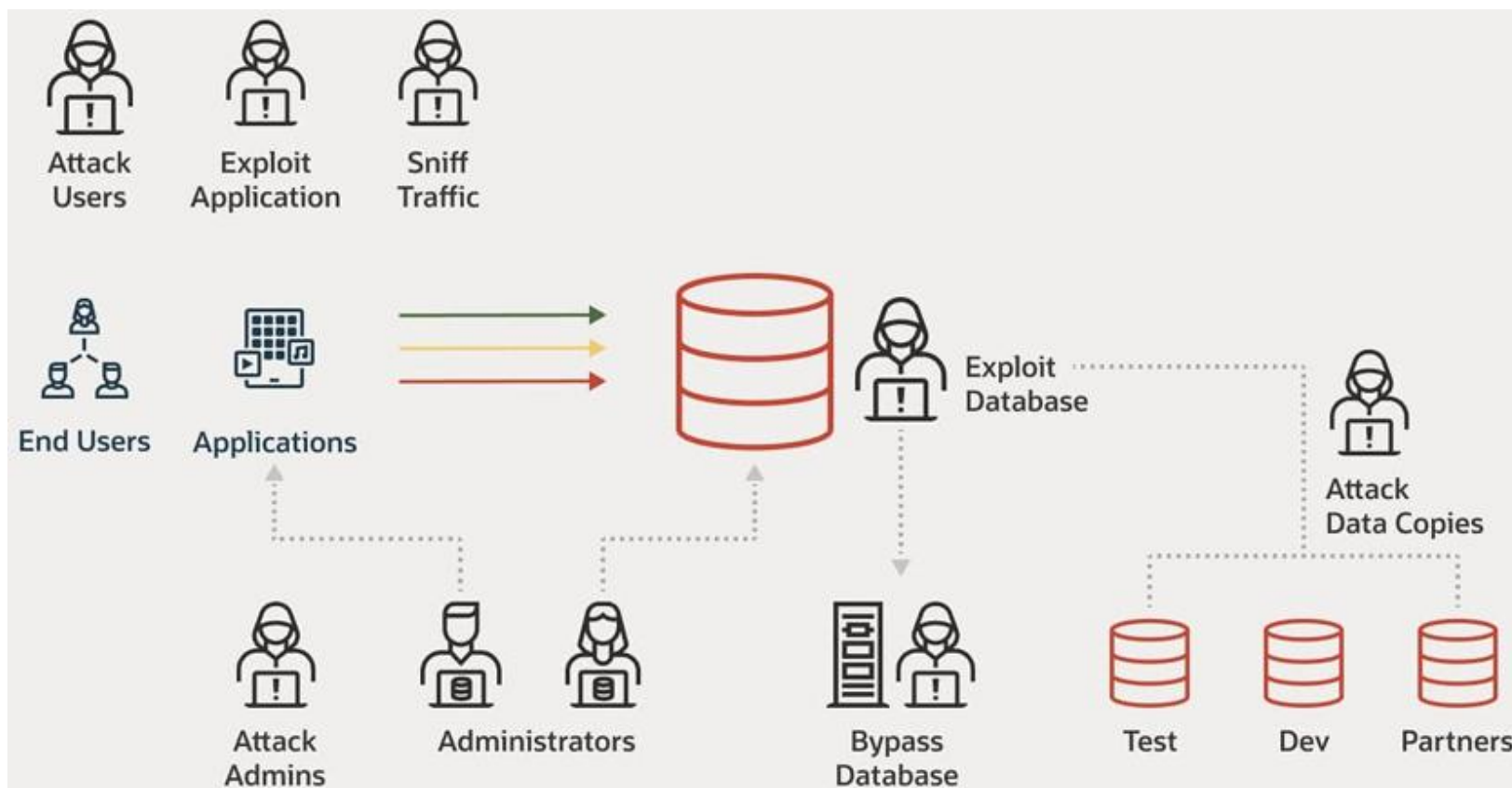
An toàn cơ sở dữ liệu có ý nghĩa quan trọng trong kinh doanh vì sự mất an toàn có thể dẫn đến các hậu quả nghiêm trọng :

- ☐ Trộm cắp dữ liệu: Trộm cắp dữ liệu có giá trị, bí mật và nhạy cảm.
- ☐ Thiệt hại về kinh doanh và uy tín thương hiệu: Mất các hợp đồng, hợp tác kinh doanh
- ☐ Mất doanh thu: những vi phạm dữ liệu có thể tạm dừng hoặc làm chậm hoạt động kinh doanh và mất doanh thu
- ☐ Tăng chi phí: việc khắc phục vi phạm dữ liệu rất tốn kém, gồm phí pháp lý, hỗ trợ nạn nhân, chi phí bổ sung để khôi phục dữ liệu ...
- ☐ Hình phạt vi phạm vi phạm dữ liệu: bị phạt theo quy định về mất an toàn hoặc tiền trong một số trường hợp yêu cầu phải bồi thường

- ❑ An toàn CSDL là sự bảo vệ dữ liệu trong CSDL chống lại những truy nhập, sửa đổi hay phá hủy bất hợp pháp.
- ❑ Để đảm bảo tính an toàn cho CSDL, cần có một bộ công cụ, quy trình và phương pháp thiết lập bảo mật bên trong môi trường CSDL để đảm bảo:
 - Tính bảo mật, tính sẵn sàng, tính toàn vẹn của CSDL (CIA Triad)
- ❑ Các chương trình an toàn CSDL được thiết kế để các thành phần sau được an toàn:
 - Dữ liệu trong cơ sở dữ liệu
 - Hệ thống quản lý dữ liệu
 - Mọi ứng dụng truy cập vào nó

- ❑ Vấn đề bảo mật CSDL thực hiện trên diện rộng, bao gồm
 - Các vấn đề pháp lý, đạo đức, chính sách và liên quan đến hệ thống
- ❑ Các loại mối đe dọa đối với CSDL
 - Mất tính toàn vẹn: Sửa đổi thông tin không đúng
 - Mất tính khả dụng: Người dùng hợp pháp không thể truy cập các đối tượng dữ liệu
 - Mất tính bí mật: Tiết lộ trái phép thông tin bí mật
- ❑ CSDL là kho lưu trữ thông tin nhạy cảm có giá trị, khiến chúng trở thành mục tiêu chính của kẻ trộm dữ liệu

Tội phạm mạng có nhiều cách tiếp cận khác nhau để sử dụng khi đánh cắp dữ liệu từ CSDL



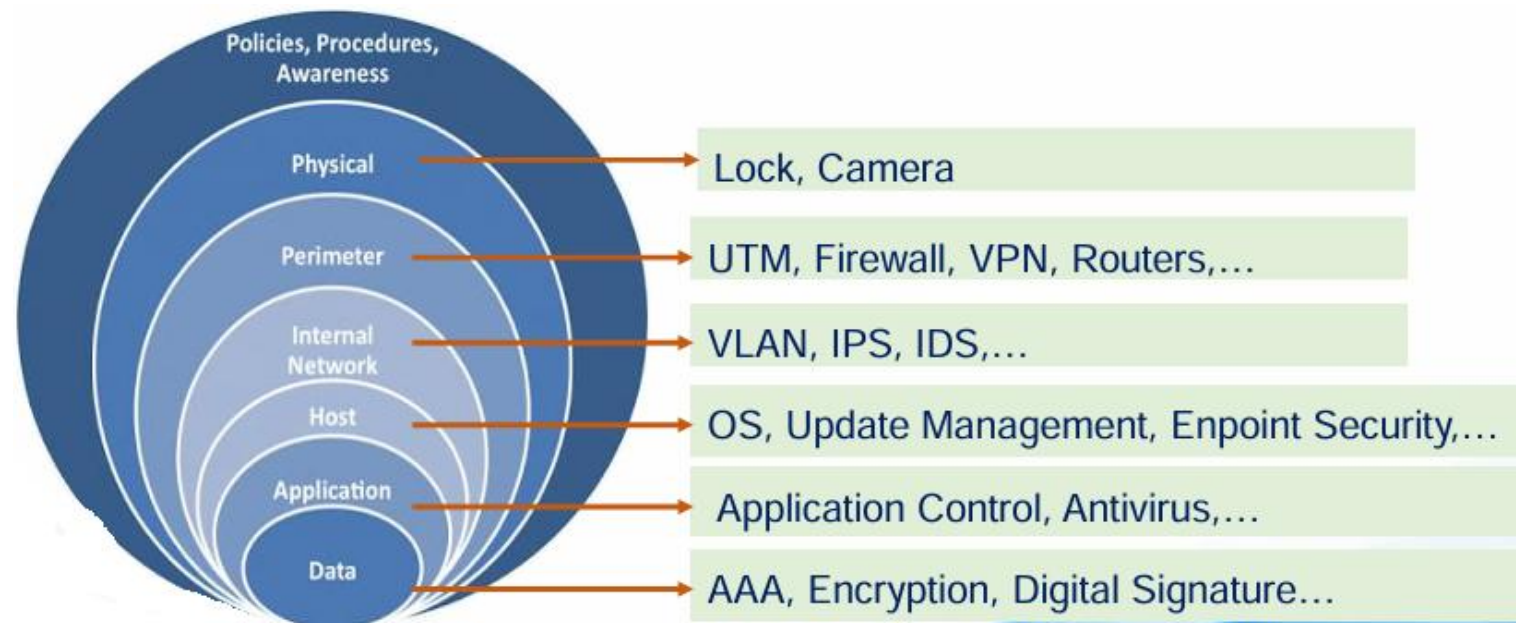
❑ Một số mối đe dọa như:

- Ăn cắp thông tin đăng nhập của quản trị viên hoặc ứng dụng có đặc quyền.
- Khai thác các điểm yếu, như SQL Injection
- Nâng cao đặc quyền bằng cách khai thác các ứng dụng dễ bị tấn công.
- Truy cập các tệp CSDL không được mã hóa trên đĩa.
- Khai thác các lỗi chưa được vá hoặc cấu hình sai để vượt qua các biện pháp kiểm soát.

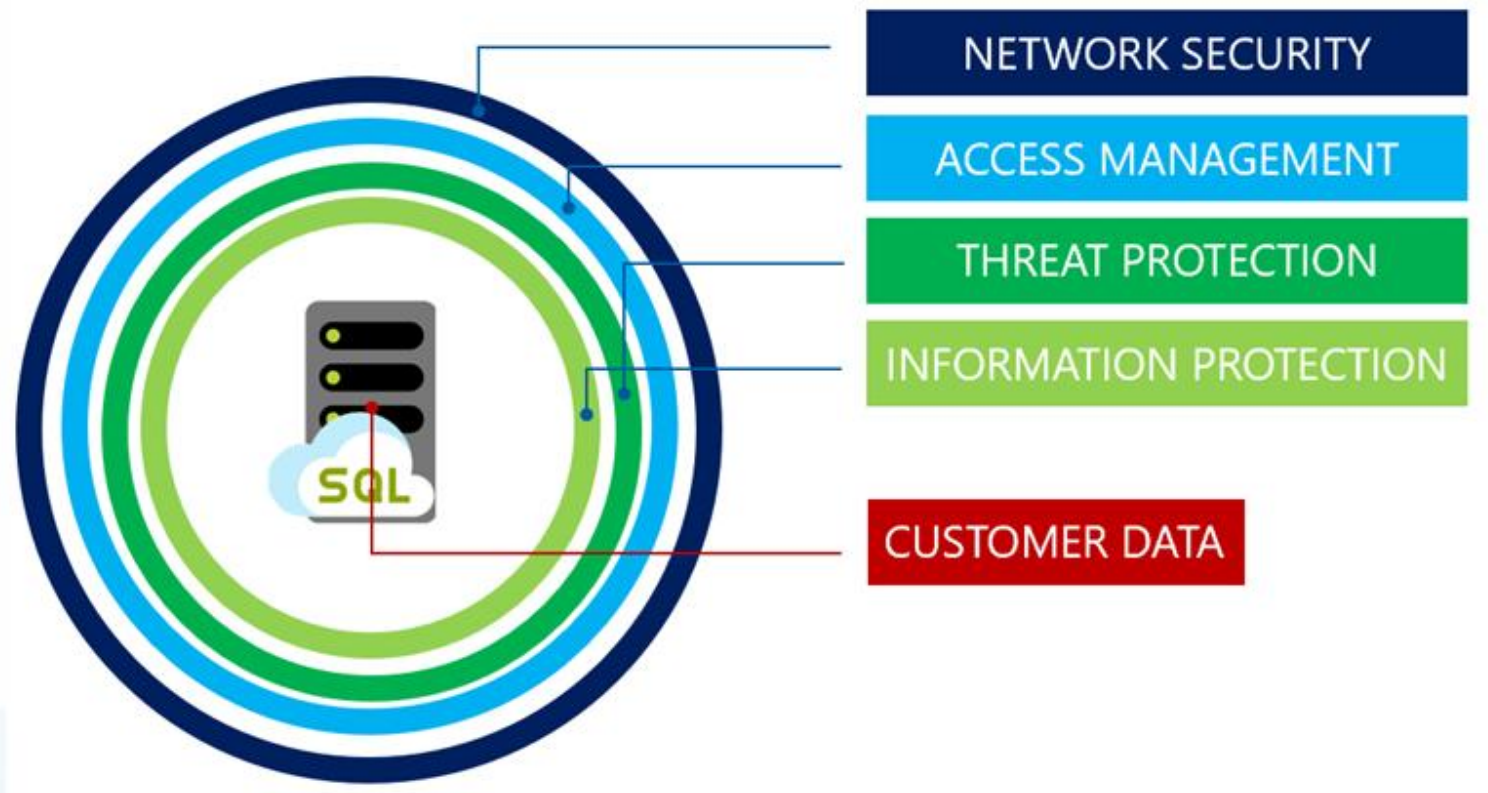
❑ Một số mối đe dọa như:

- Ăn cắp thiết bị lưu trữ và phương tiện chứa bản sao lưu CSDL.
- Đánh cắp dữ liệu từ các môi trường phi sản xuất, chẳng hạn như DevTest.
- Xem dữ liệu nhạy cảm thông qua các ứng dụng vô tình làm lộ dữ liệu nhạy cảm.
- Lỗi của con người, sự cố, chia sẻ mật khẩu, lỗi cấu hình và hành vi vô trách nhiệm khác của người dung.

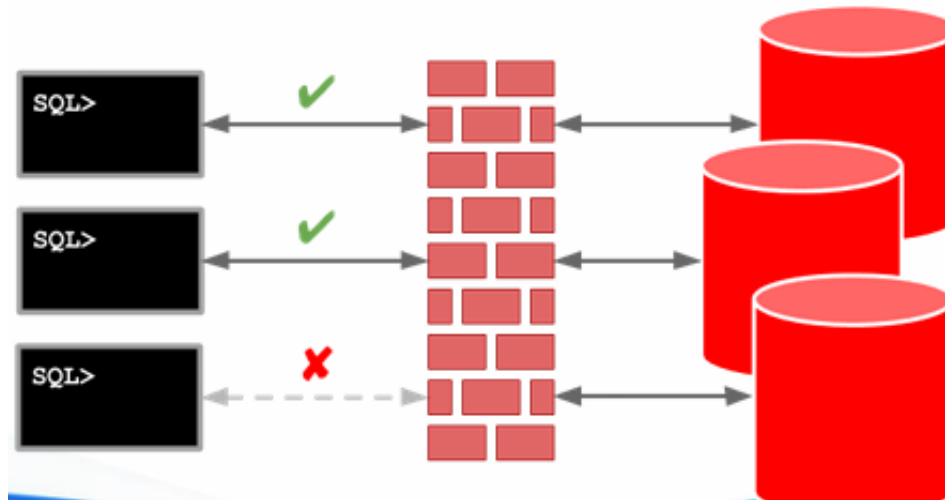
Để đạt được mức độ bảo mật CSDL cao nhất, các tổ chức cần có nhiều lớp bảo vệ. Chiến lược bảo mật phòng thủ chuyên sâu (DiD-Defense in Depth) đặt nhiều biện pháp kiểm soát trên toàn hệ thống CNTT. Nếu một lớp bảo vệ bị lỗi thì lớp bảo vệ khác sẽ được áp dụng để ngăn chặn cuộc tấn công ngay lập tức.



Các lớp bảo vệ dữ liệu quan trọng

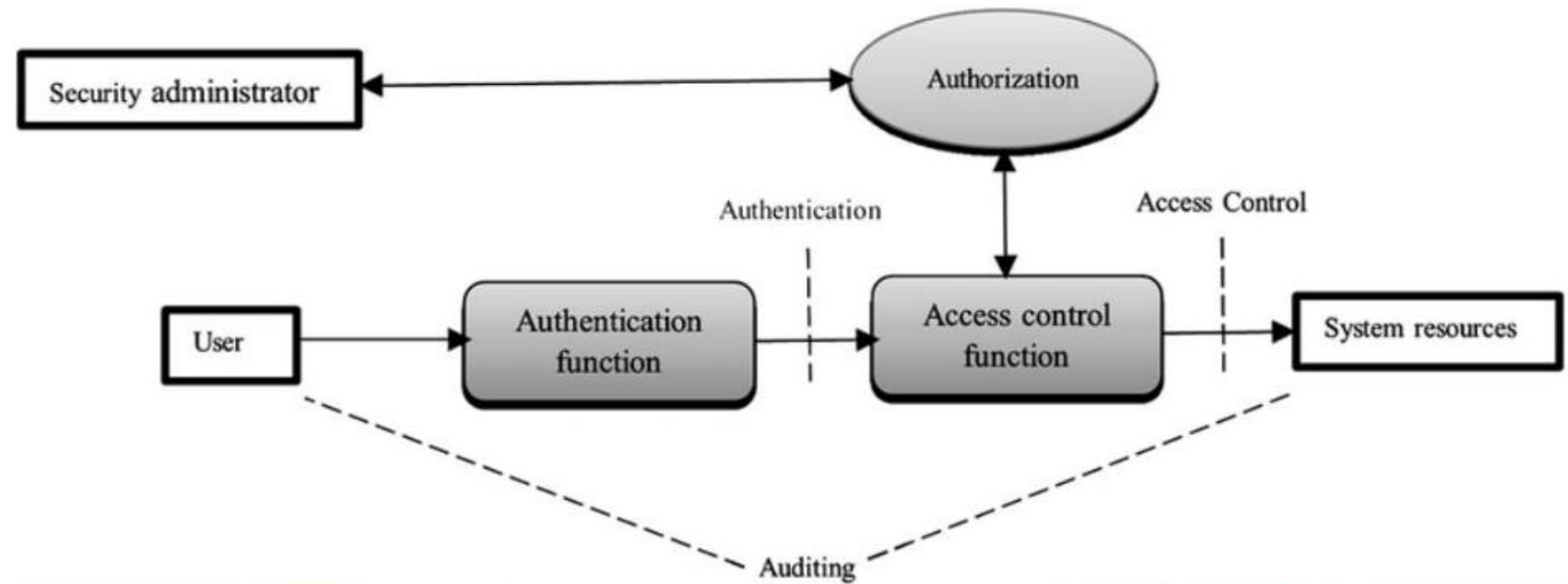


- ❑ Firewall đóng vai trò là tuyến phòng thủ đầu tiên trong bảo mật CSDL. Một bộ phân tách hoặc bộ hạn chế lưu lượng truy cập mạng, có thể được định cấu hình để thực thi chính sách bảo mật dữ liệu của tổ chức tăng cường bảo mật ở cấp hệ điều hành bằng cách cung cấp một điểm nghẽn nơi các biện pháp bảo mật của bạn có thể được tập trung.
- ❑ Đảm bảo rằng Firewall được cấu hình đúng cách để khắc phục mọi điểm yếu về bảo mật



Bao gồm các chức năng:

- ☐ Authentication: DB, OS
- ☐ Authorization
- ☐ Access control
- ☐ Auditing



❑ Các model Access control:

- Kiểm soát truy cập bắt buộc (MAC): Phân loại dữ liệu và người dùng thành các lớp bảo mật khác nhau
- Kiểm soát truy cập tùy ý (DAC): Dùng để cấp đặc quyền cho người dùng
- Kiểm soát truy cập dựa trên vai trò (RBAC): có thể tùy chỉnh quyền của các vai trò cơ sở dữ liệu do người dùng xác định bằng cách sử dụng GRANT, DENY và REVOKE.
- Bảo mật cấp hàng (Row-level security): kiểm soát quyền truy cập vào các hàng trong bảng CSDL. Triển khai bằng cách sử dụng câu lệnh CREATE SECURITY POLICY (Transact-SQL)

- ❑ Phát hiện các hoạt động bất thường cho thấy mối đe dọa bảo mật tiềm ẩn đối với CSDL có thể hiển thị thông tin về các sự kiện đáng ngờ trực tiếp cho quản trị viên.
- ❑ Các mối đe dọa phổ biến bao gồm các cuộc tấn công SQL Injection, tấn công Brute force và khai thác các lỗ hổng phần mềm lỗi thời.



- ☐ Mã hóa dữ liệu: Mã hóa dữ liệu ở mức lưu trữ, trong quá trình truyền, tại Server, tại client. (sử dụng TLS).
- ☐ Sao lưu dữ liệu và phục hồi tạo các bản sao lưu cơ sở dữ liệu và tệp nhật ký một cách thường xuyên và lưu trữ các bản sao ở một vị trí an toàn. Sẵn sàng khôi phục cơ sở dữ liệu trong trường hợp vi phạm hoặc lỗi bảo mật.
- ☐ Bảo mật cho các ứng dụng máy chủ web và trang web: Bất kỳ ứng dụng hoặc máy chủ web nào kết nối với cơ sở dữ liệu đều có thể là mục tiêu và phải được kiểm tra bảo mật định kỳ cũng như quản lý các biện pháp tốt nhất.
- ☐ Bảo mật vật lý: giới hạn quyền truy cập vào máy chủ vật lý và các thành phần phần cứng.

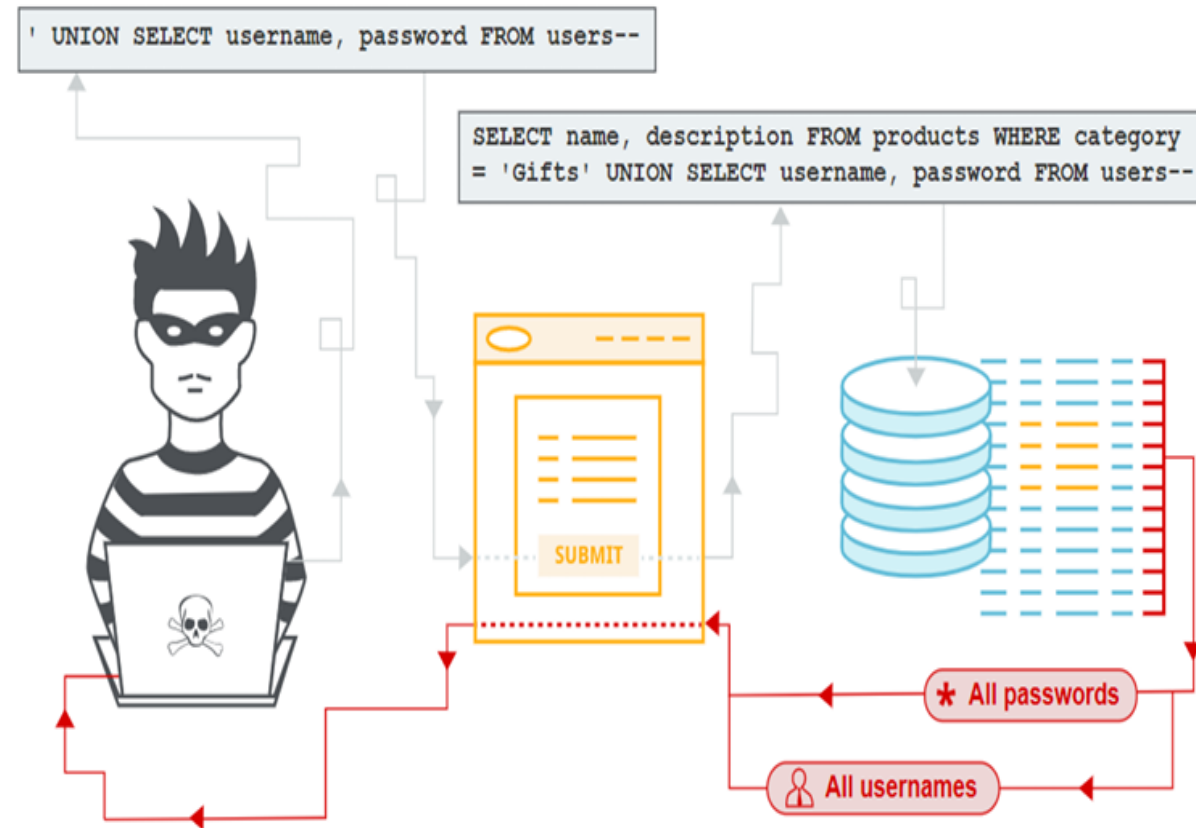
- ❑ **SQL Injection:** kẻ tấn công lợi dụng lỗ hổng của việc kiểm tra dữ liệu đầu vào trong các ứng dụng web và các thông báo lỗi của hệ quản trị cơ sở dữ liệu trả về để inject và thi hành các câu lệnh SQL bất hợp pháp.
- ❑ **Inference attacks:** là quá trình thực hiện các truy vấn được ủy quyền và suy luận các thông tin trái phép từ các câu trả lời hợp lệ

- ❑ Xảy ra khi ứng dụng web ghép dữ liệu đầu vào của người dùng vào câu lệnh SQL mà không ràng buộc/kiểm tra đúng cách.
- ❑ Kẻ tấn công có thể đọc dữ liệu trái phép (Confidentiality), sửa/xóa dữ liệu (Integrity), thậm chí gây gián đoạn dịch vụ (Availability).
- ❑ SQL injection phổ biến vì nhiều ứng dụng xử lý input và truy vấn DB trực tiếp; chỉ cần một điểm nhập liệu (form, URL, API) là có thể bị khai thác.

Hoạt động:

- Đóng chuỗi để thoát khỏi phần điều kiện ban đầu
- Chèn mệnh đề (ví dụ dạng UNION) để “ghép” thêm kết quả trả về
- Comment out phần còn lại để tránh lỗi cú pháp “--”.

Ví dụ: từ khóa UNION, cho phép thực thi một truy vấn SELECT bổ sung và nối kết quả vào truy vấn ban đầu => trả về tất cả username/pass, tên và mô tả của sản phẩm.



- ❑ **User input:** Dữ liệu do người dùng cung cấp qua form, URL/query string, tham số API (JSON/body). Nếu ứng dụng ghép trực tiếp vào câu SQL mà không ràng buộc đúng cách có thể gây SQLi.
- ❑ **Client-controlled data (Cookies/Headers):** Cookie và các HTTP header (ví dụ: User-Agent, Referer, X-Forwarded-For...) có thể bị giả mạo. Nếu ứng dụng dùng các giá trị này để xây dựng truy vấn SQL thì có nguy cơ SQLi.
- ❑ **Second-order injection:** Payload độc hại được lưu vào hệ thống/CSDL trước (ví dụ trong profile, comment, log...). Ở một thời điểm khác, ứng dụng đọc lại dữ liệu này và ghép vào câu SQL, từ đó kích hoạt SQL injection.

- ❑ **Server-side / log-derived data:** Dữ liệu nội bộ như log ứng dụng, dữ liệu đồng bộ từ hệ thống khác, hoặc các biến môi trường nếu được đưa vào truy vấn SQL mà không xử lý an toàn vẫn có thể trở thành nguồn gây SQLi.
- ❑ **External / physical input:** Dữ liệu từ thiết bị hoặc kênh vật lý (OCR, QR/barcode, POS/IoT...) khi được chuyển vào hệ thống backend và dùng trong truy vấn SQL cũng phải coi là untrusted và cần kiểm soát như user input.

Truy xuất dữ liệu ẩn

Ví dụ:

Khi user click Gifts category, URL: <https://insecure-website.com/products?category=Gifts>

Một truy vấn SQL để lấy thông tin chi tiết:

*SELECT * FROM products WHERE category = 'Gifts' AND released = 1*

❑ Kẻ tấn công Attacker có thể xây dựng một cuộc tấn công như:

<https://insecure-website.com/products?category=Gifts'-->

Nghĩa là: *SELECT * FROM products WHERE category = 'Gifts'--' AND released = 1*--loại bỏ phần còn lại của truy vấn, do đó nó không còn chứa *AND released = 1*

Logic của ứng dụng:

Ví dụ

Nếu người dùng gửi **wiener** tên người dùng và mật khẩu **bluecheese**, ứng dụng sẽ kiểm tra thông tin đăng nhập bằng cách thực hiện truy vấn SQL sau:

```
SELECT * FROM users WHERE username = 'wiener' AND password = 'bluecheese'
```

Nếu truy vấn trả về thông tin chi tiết của người dùng thì đăng nhập thành công. Nếu không, nó sẽ bị từ chối.

Logic của ứng dụng:

Ví dụ:

Tại đây, kẻ tấn công có thể đăng nhập với tư cách bất kỳ người dùng nào mà không cần mật khẩu chỉ bằng cách sử dụng chuỗi nhận xét SQL -- để xóa kiểm tra mật khẩu khỏi mệnh đề WHERE của truy vấn.

```
SELECT * FROM users WHERE username = 'administrator'--' AND password = ''
```

Truy vấn này trả về người dùng có tên người dùng là quản trị viên và đăng nhập thành công kẻ tấn công với tư cách là người dùng đó.

Các cuộc tấn công UNION: để lấy dữ liệu từ các bảng khác trong CSDL.

Trường hợp kết quả của truy vấn SQL được trả về trong phản hồi của ứng dụng, kẻ tấn công có thể tận dụng lỗ hổng SQLi, bằng cách sử dụng từ khóa UNION thực thi một truy vấn SELECT bổ sung và nối kết quả vào truy vấn ban đầu.

Ví dụ, nếu một ứng dụng thực hiện truy vấn sau có chứa "Gifts" do người dùng nhập:

SELECT name, description FROM products WHERE category = 'Gifts'

sau đó kẻ tấn công có thể gửi đầu vào:

' UNION SELECT username, password FROM users-

Điều này sẽ khiến ứng dụng trả về tất cả tên người dùng và mật khẩu cùng với tên và mô tả của sản phẩm

Kiểm tra thông tin cơ sở dữ liệu:

❑ Sau khi xác định ban đầu về lỗ hổng SQL injection, thông thường sẽ hữu ích khi lấy một số thông tin về chính CSDL. Thông tin này thường có thể mở đường cho việc khai thác thêm.

❑ Ta có thể truy vấn chi tiết phiên bản cho CSDL. Cách thực hiện điều này phụ thuộc vào loại CSDL, vì vậy ta có thể suy ra loại CSDL từ bất kỳ kỹ thuật nào hoạt động. Ví dụ

*SELECT * FROM v\$version*

❑ Ta cũng có thể xác định bảng CSDL nào tồn tại và chúng chứa những cột nào. Ví dụ: trên hầu hết các CSDL, ta có thể thực hiện truy vấn sau để liệt kê các bảng

*SELECT * FROM information_schema.tables*

❑ Blind SQL Injection :

- Nhiều trường hợp SQL injection là lỗ hổng không trả về kết quả của truy vấn SQL hoặc chi tiết lỗi CSDL nào trong các phản hồi của nó.
- Các lỗ hổng bảo mật vẫn có thể bị khai thác để truy cập dữ liệu trái phép.

- ❑ Công cụ: sử dụng trình quét lỗ hổng web của Burp Suite.
- ❑ Thủ công: sử dụng một bộ thử nghiệm có hệ thống đối với mọi điểm vào trong ứng dụng.
 - Gửi ký tự trích dẫn đơn ' và tìm kiếm lỗi hoặc các điểm bất thường khác.
 - Gửi một số cú pháp dành riêng cho SQL để đánh giá giá trị cơ sở (gốc) của điểm nhập và một giá trị khác, đồng thời tìm kiếm sự khác biệt mang tính hệ thống trong các phản hồi của ứng dụng thu được.

- ❑ Thủ công: sử dụng một bộ thử nghiệm có hệ thống đối với mọi điểm vào trong ứng dụng.
 - Gửi các điều kiện Boolean như `OR 1=1` và `OR 1=2` và tìm kiếm sự khác biệt trong phản hồi của ứng dụng.
 - Gửi payload được thiết kế để kích hoạt độ trễ thời gian khi được thực thi trong truy vấn SQL và tìm kiếm sự khác biệt về thời gian cần thiết để phản hồi.
 - Gửi payload OAST được thiết kế để kích hoạt tương tác mạng ngoài khi được thực thi trong truy vấn SQL và giám sát mọi tương tác phát sinh

❑ Sử dụng các truy vấn được tham số hóa (còn được gọi là câu lệnh đã chuẩn bị sẵn) thay vì nối chuỗi trong truy vấn. Đoạn mã sau dễ bị tấn công:

```
String query = "SELECT * FROM products WHERE category = '"+ input + "'";
```

```
Statement statement = connection.createStatement();
```

```
ResultSet resultSet = statement.executeQuery(query);
```

❑ Mã được viết lại ngăn chặn đầu vào của người dùng can thiệp vào cấu trúc truy vấn:

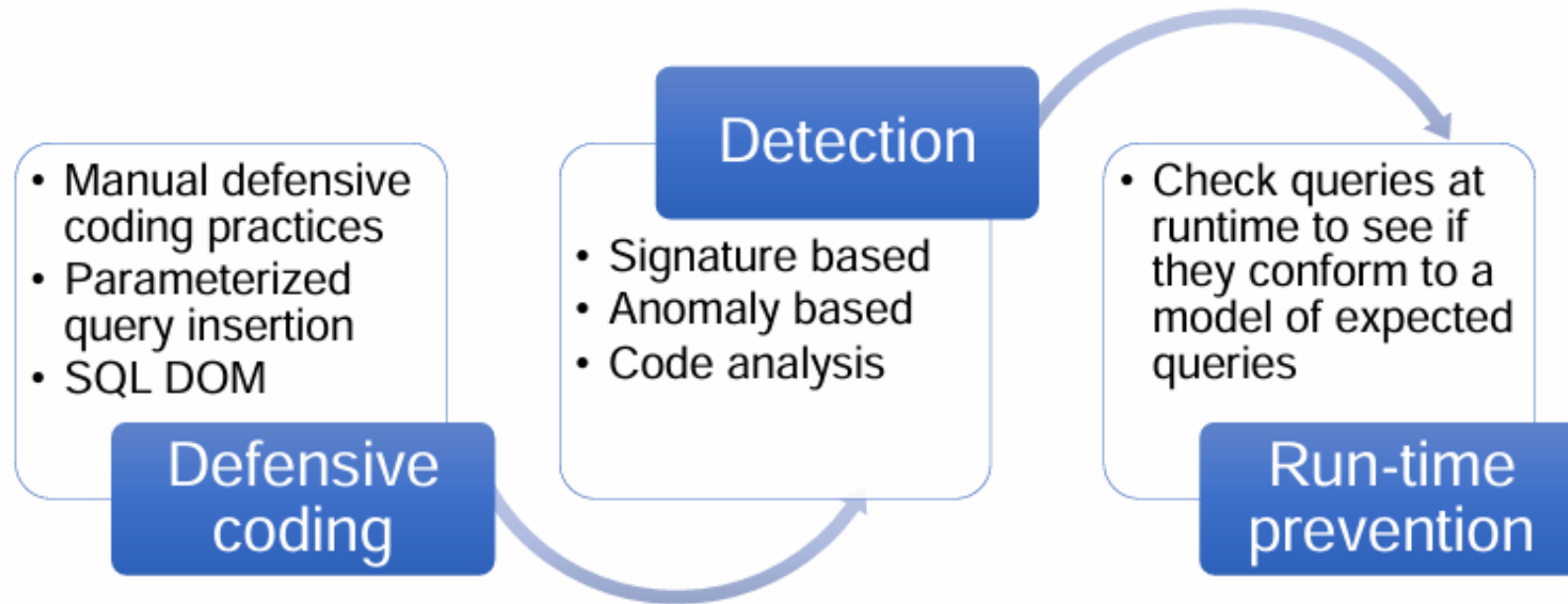
```
PreparedStatement statement = connection.prepareStatement("SELECT * FROM products  
WHERE category = ?");
```

```
statement.setString(1, input);
```

```
ResultSet resultSet = statement.executeQuery();
```

- ❑ Truy vấn tham số hoá (Prepared/Parameterized Query) dùng được khi input của người dùng chỉ đóng vai trò là dữ liệu trong truy vấn:
 - Giá trị trong mệnh đề WHERE
 - Giá trị trong INSERT / UPDATE
- ❑ Không dùng tham số hoá cho các phần thuộc cấu trúc câu SQL (không thể đặt ?):
 - Tên bảng/cột, ORDER BY, ASC/DESC, toán tử...
- ❑ Cách xử lý khi input ảnh hưởng cấu trúc:
 - Dùng whitelist (chỉ cho phép chọn từ danh sách giá trị hợp lệ), hoặc
 - Thiết kế lại logic để tránh ghép SQL động

Cần có một bộ kỹ thuật tích hợp:



Tấn công suy luận, liên quan đến bảo mật cơ sở dữ liệu, là quá trình thực hiện các truy vấn được ủy quyền và suy luận các thông tin trái phép từ các câu trả lời hợp lệ. Khi kết hợp các mục dữ liệu riêng lẻ có thể được sử dụng để suy luận ra dữ liệu có độ nhạy cảm cao hơn.

Dữ liệu y tế ẩn danh

SSN	Name	Race	DOB	Sex	Zip	Marital	Heath
		Asian	09/07/64	F	22030	Married	Obesity
		Black	05/14/61	M	22030	Married	Obesity
		White	05/08/61	M	22030	Married	Chest pain
		White	09/15/61	F	22031	Widow	Aids

Danh sách cử tri có sẵn công khai

Name	Address	City	Zip	DOB	Sex	Party
....						
Sue Carlson	900 Market St.	Fairfax	22031	09/15/61	F	Democrat

Sue Carlson has Aids!

Tấn công gián tiếp: kết hợp nhiều tập hợp

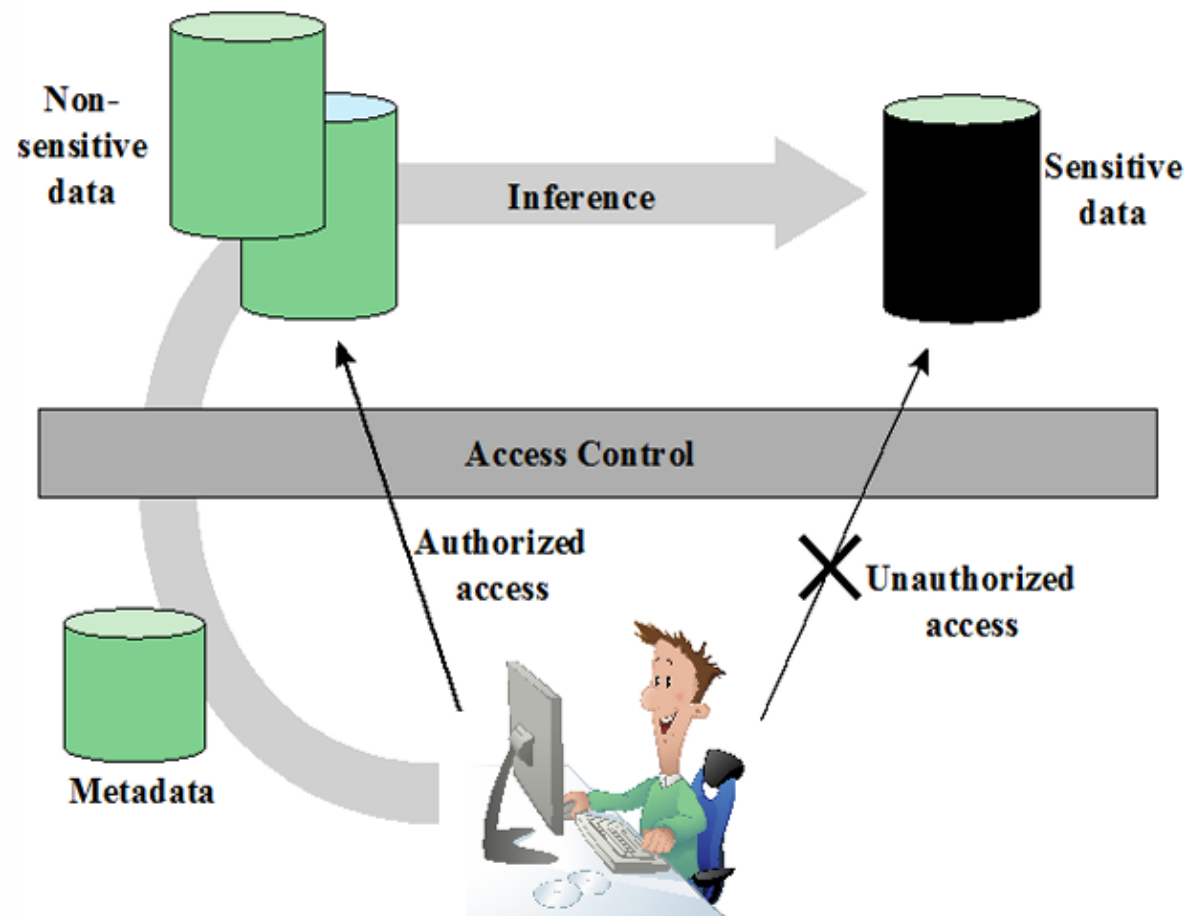
Ví dụ

- ☐ 1 Male in Holmes nhận 5000
- ☐ 1 Female in Grey nhận là no aid
- ☐ Yêu cầu danh sách tên theo Dorm (không nhạy cảm)

Sums of Financial Aid by Dorm and Sex				
	Holmes	Grey	West	Total
M	5000	3000	4000	12000
F	7000	0	4000	11000
Total	12000	3000	8000	23000

Students by Dorm and Sex				
	Holmes	Grey	West	Total
M	1	3	1	5
F	2	1	3	6
Total	3	4	4	11

- ❑ Tấn công gián tiếp: kênh suy luận - đường dẫn chuyển thông tin có chứa dữ liệu trái phép
- ❑ Hai kỹ thuật suy luận có thể được sử dụng để lấy được thông tin bổ sung:
 - Phân tích các phụ thuộc chức năng giữa các thuộc tính trong một bảng hoặc trên các bảng,
 - Sáp nhập các quan điểm với những ràng buộc tương tự.



Tấn công theo dõi: kiểu tấn công gián tiếp (rất hiệu quả)

- ❑ Lỗ hổng hệ thống tuyến tính: thực hiện các cuộc tấn công theo dõi sâu hơn, sử dụng quan hệ đại số giữa các bộ truy vấn để xây dựng các phương trình mang lại thông tin mong muốn
- ❑ Trình theo dõi có thể xác định giá trị duy nhất
 - Giá trị yêu cầu (n) và $(n-1)$
 - Cho trước n và $n - 1$, chúng ta có thể dễ dàng tính toán phần tử đơn lẻ mong muốn



2 cách

Phát hiện suy luận trong quá trình thiết kế CSDL

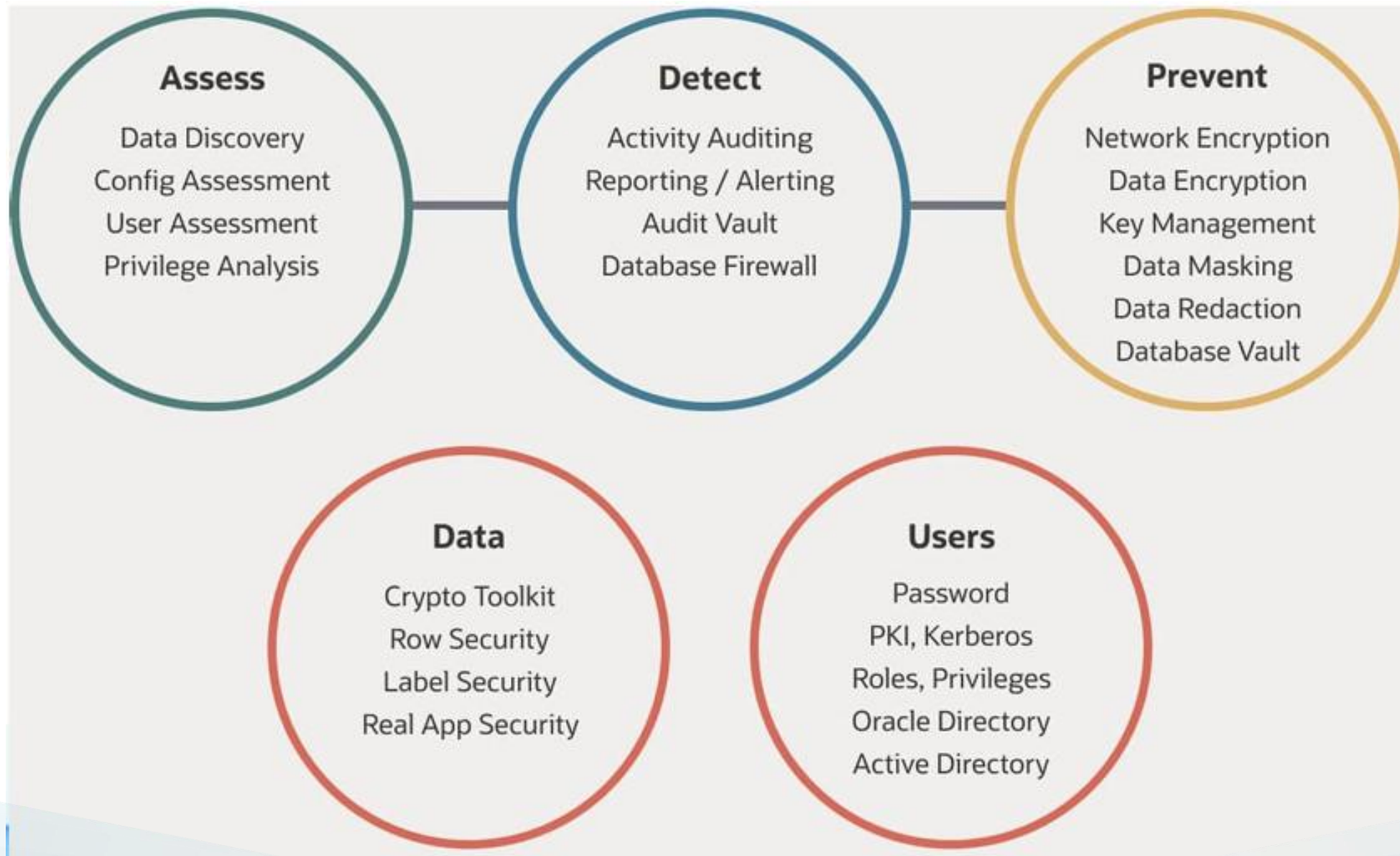
loại bỏ kênh suy luận bằng cách thay đổi cấu trúc cơ sở dữ liệu hoặc bằng cách thay đổi chế độ kiểm soát truy cập để ngăn chặn suy luận

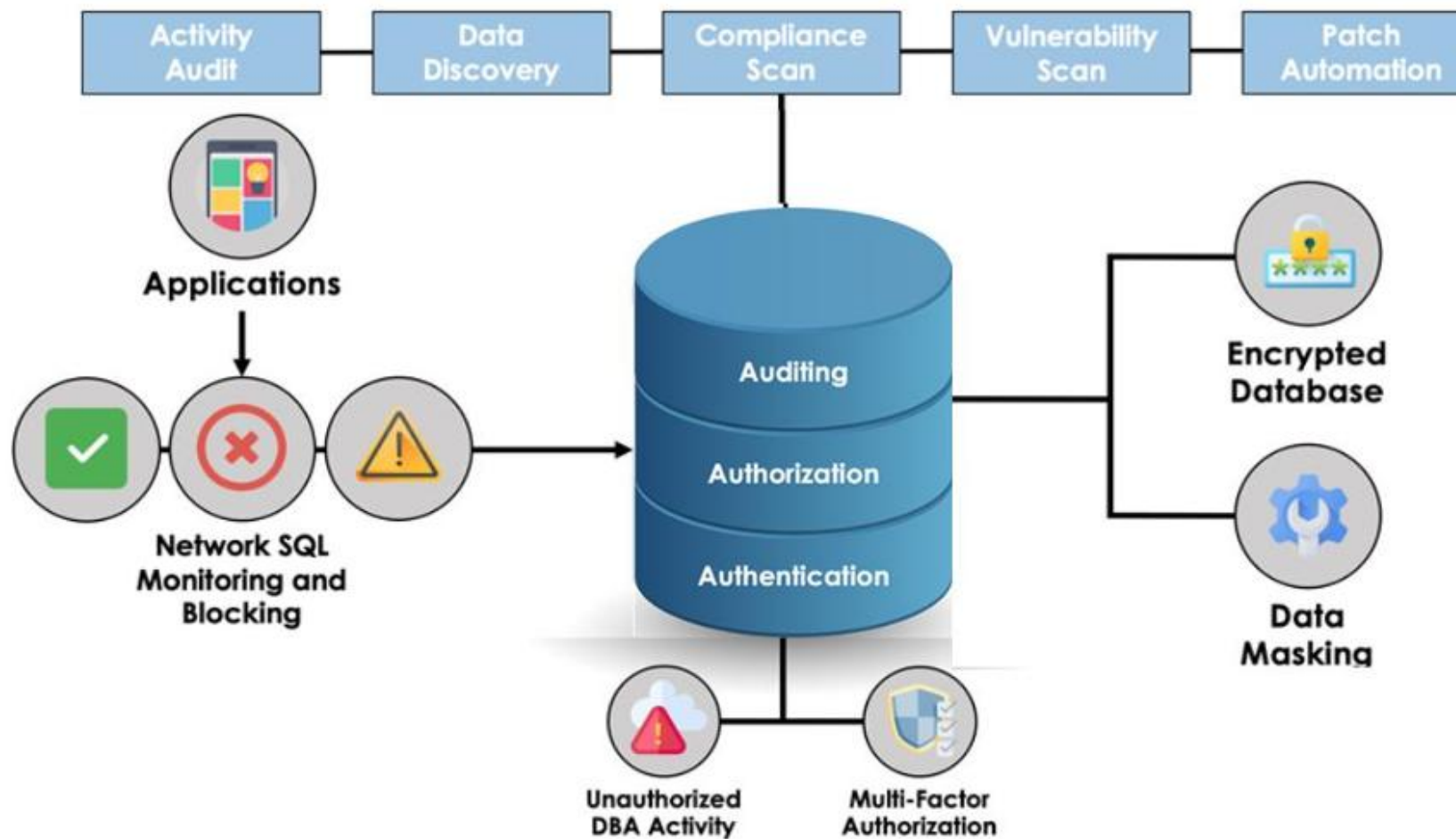
thường dẫn đến các biện pháp kiểm soát truy cập chặt chẽ hơn một cách không cần thiết làm giảm tính khả dụng

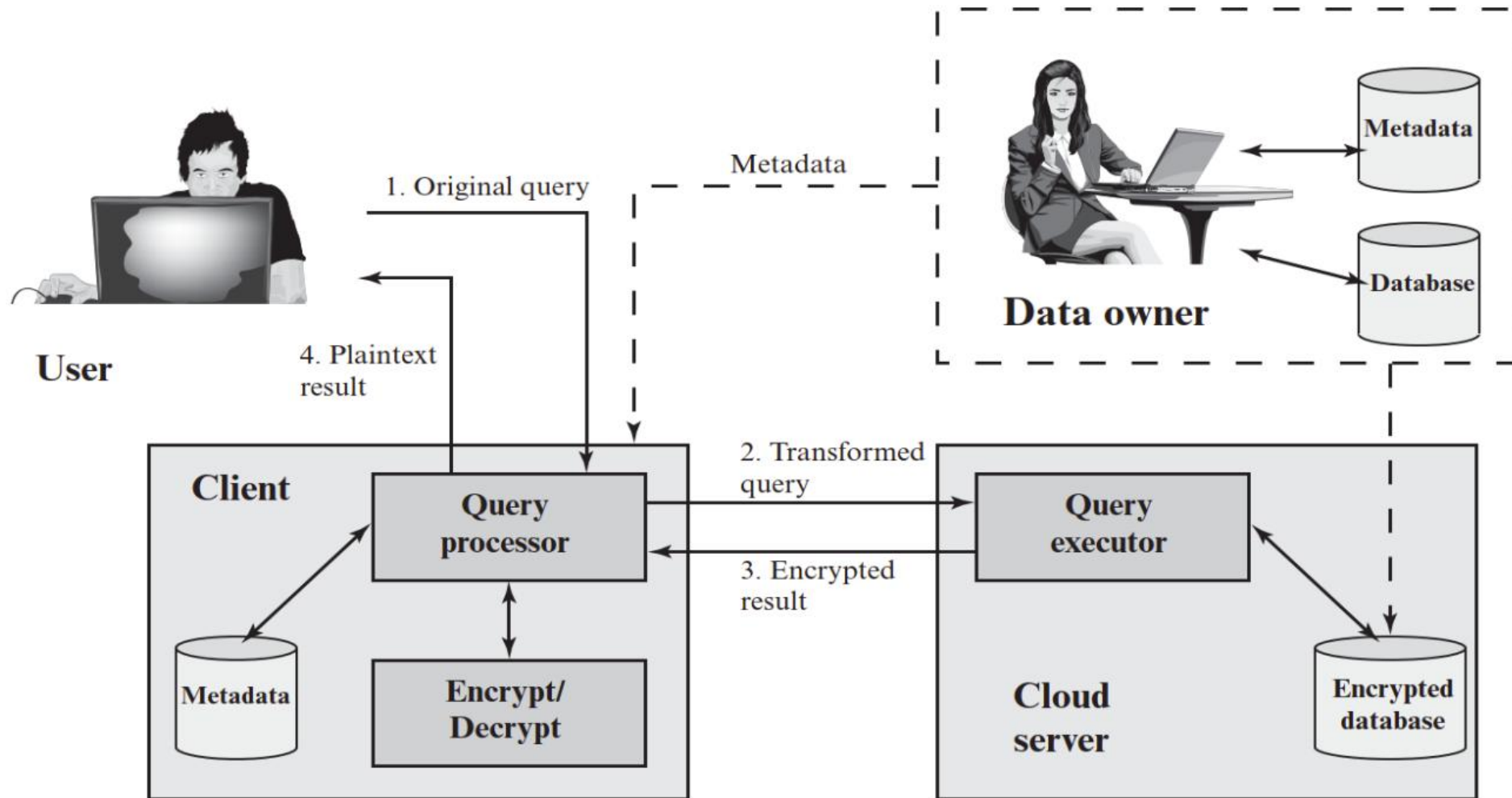
Phát hiện suy luận tại thời điểm truy vấn

tìm cách loại bỏ vi phạm kênh suy luận trong một truy vấn hoặc một loạt truy vấn

nếu phát hiện thấy kênh suy luận, truy vấn sẽ bị từ chối hoặc bị thay đổi







Computer Security prepared by Prof. Dr. Haider Tarish Haider Second edition 2025

- ☐ Tầm quan trọng của việc an toàn cơ sở dữ liệu
- ☐ Cấu trúc cơ sở dữ liệu tác động đến các cơ chế an toàn
- ☐ Các cơ chế an toàn trong các cơ sở dữ liệu
- ☐ Các cuộc tấn công phổ biến
- ☐ Phòng chống tấn công cơ sở dữ liệu

1. Một trong những lớp bảo vệ CSDL

a. Bảo vệ người dùng

b. Bảo vệ mạng

c. Bảo vệ vật lý

d. Bảo vệ file

3. Giải pháp mã hóa dữ liệu thuộc lớp bảo vệ CSDL nào

a. Bảo vệ người dùng

b. Bảo vệ mạng

c. Bảo vệ dữ liệu

d. Quản lý truy xuất



AN TOÀN THÔNG TIN (INSE330380)

Kết thúc chương 4

Ths. ĐỖ MINH HẬU



Trung tâm Học liệu và Dạy học số
Đại học Công nghệ Kỹ thuật Tp. Hồ Chí Minh
01 Võ Văn Ngân, P. Thủ Đức, Tp. Hồ Chí Minh
daotaotuxa@hcmute.edu.vn